
Operational Policy

Policy title: Information Security Risk Assessment Policy

Policy number: ODHSOHA 090-006

Original policy date: 03/11/2015

Last update: 07/01/2026

Approved by: Kris Kautz, OHA and Seth Lyon, ODHS

Purpose

The Oregon Department of Human Services (ODHS) and Oregon Health Authority (OHA) are committed to ensuring the confidentiality, integrity, and availability of information assets and systems by safeguarding their physical security and protecting those assets from unauthorized access, modification, destruction, or disclosure. The purpose of an information security risk assessment (ISRA) is to identify and assess the threats and vulnerabilities that pose a risk to ODHS and OHA information technology assets.

Description

This policy ensures that ODHS and OHA information assets and systems are assessed for potential risks and vulnerabilities so the agencies can maintain the confidentiality, integrity, and availability of all protected information.

Applicability

This policy applies to all ODHS and OHA staff, including full-time, part-time, contingent, temporary, and limited duration employees, volunteers, trainees, and interns. The requirements of this policy also apply to contractors, grantees, and partners in their delivery of goods or services to or on behalf of either agency, as required under the applicable contract, grant, or other form of agreement.

As keepers of the public trust, all ODHS and OHA staff play a vital role in upholding state and agency policies, administrative rules, and state and federal laws. ODHS and OHA are committed to exceptional public and customer service. The agencies are dedicated to maintaining standards of exceptional service and trust staff to do the same. Failure to follow policies, rules and laws may result in beginning a personnel process to consider formal action as appropriate, including progressive discipline up to and including dismissal from state service.

Policy

1. ODHS and OHA shall develop, implement, and maintain an information security risk assessment program that identifies threats and vulnerabilities to information assets and systems including all forms of physical and digital media.
 - a. Information assets include any knowledge that can be communicated or documentary material, regardless of its physical form or characteristics, that has value to the organization.¹
 - b. Information systems are a discrete set of information resources organized for the collection, processing, maintenance, use, sharing, dissemination, or disposition of information.²
 - c. Information systems include computers, hardware, software, storage media, networks, operational procedures, and processes used in the collection, processing, storage, sharing or distribution of information within the state's shared computing and network infrastructure, beyond ordinary public access.
 - d. Digital media is any form of electronic media designed to store data in a digital format.
2. The Information Security and Privacy Office (ISPO) shall manage and coordinate information security risk assessments of agency assets to evaluate how controls protect the confidentiality, integrity, and availability of

¹ Department of Administrative Services (DAS) 107-004-110 Acceptable Use of State Information Assets Policy

² National Institute of Standards and Technology (NIST) 800-37 Rev. 2 Risk Management Framework for Information Systems and Organizations

these assets, as required by law, the ODHS and OHA Agency Information Security Plan, and based on the information assets contained in each system.

3. ISPO shall use information security risk assessments to advise the agency on appropriate measures to safeguard against identified risks, in accordance with federal and state statutes and rules as well as program requirements.
4. An information security risk assessment (ISRA) identifies and assesses threats and vulnerabilities that pose a risk to ODHS and OHA information assets, supports the management of risk, and guides selection of cost-effective controls. ISRAs shall include an evaluation of the following:
 - a. Managerial controls.
 - b. Operational controls.
 - c. Technical controls.
 - d. Compliance requirements.
 - e. Effects on privacy and related safeguards, as necessary.
5. Information security risk assessments shall be performed:
 - a. As directed based on the statutory and regulatory requirements.
 - b. When initiated by the Chief Information Officer (CIO) or designee, or Chief Information Risk Officer (CIRO).
 - c. At the request of the agency program director or designee.
 - d. At the request of the information system owner who is accountable for the information created, transmitted, received, or processed by a specific system.
 - e. When there are significant changes to the information system, the environment of operation, or other conditions that may impact the security of the system.
 - f. To assess the agency's security posture following a security incident, as directed.

6. ISPO shall communicate the results of information security risk assessments to the following staff for inclusion in the agencies' risk evaluation and management plans:
- a. CIO.
 - b. CIRO.
 - c. Privacy Compliance Officer.
 - d. Agency program director.
 - e. Information system owner.
 - f. Chief Audit Executive for ODHS and OHA.
 - g. Local Agency Security Officer if assessment is related to criminal justice information.
 - h. Other internal regulatory liaisons if applicable.
 - i. All ODHS and OHA staff identified as supporting the risk management program shall cooperate with the information security risk assessment process.

References

[45 CFR 160 General Administrative Requirements](#)

[45 CFR 164 Security and Privacy](#)

[OAR 125-055-0100 to 125-055-0130 HIPAA Privacy and Security Rule Implementations; HITECH Act Implementation](#)

[OAR 943-014-0400 to 943-014-0465 Privacy and Confidentiality](#)

[Acceptable Risk Controls for Affordable Care Act \(ACA\), Medicaid, and Partner Entities \(ARC-AMPE\)](#)

[Criminal Justice Information Services \(CJIS\) Security Policy](#)

[Federal Information Processing Standards \(FIPS\) Publication \(Pub\) 199](#)

[Standards for Security Categorization of Federal Information and Information Systems](#)

[Federal Information Processing Standards \(FIPS\) Publication \(Pub\) 200 Minimum Security Requirements for Federal Information and Information Systems](#)

[IRS Publication 1075, Tax Information Security Guidelines for Federal, State and Local Agencies](#)

[National Institute of Standards and Technology \(NIST\) 800-30 Rev. 1 Guide for Conducting Risk Assessments](#)

[National Institute of Standards and Technology \(NIST\) 800-37 Rev. 2 Risk Management Framework for Information Systems and Organizations](#)

[National Institute of Standards and Technology \(NIST\) 800-39 Managing Information Security Risk: Organization, Mission, and Information System View](#)

[National Institute of Standards and Technology \(NIST\) 800-53 Rev. 5 Security and Privacy Controls for Information Systems and Organizations](#)

[Social Security Administration Information Exchange Security Requirements and Procedures](#)

[Statewide Information Technology \(IT\) Control Standards](#)

[Center for Internet Security Controls](#)

[ODHSOHA Agency Information Security Plan](#)

[ODHSOHA 090-006-01 Information Security Risk Assessment Process](#)

[ODHSOHA 090-006-02 Information Security Risk Assessment Process Map](#)

[ODHSOHA 090-007 Information Technology Vulnerability Management Policy](#)

[ODHSOHA 090-007-01 Continuous Vulnerability Assessment Process](#)

Related policies

[DAS 107-004-052 Cyber and Information Security](#)

[DAS 107-004-110 Acceptable Use of State Information Assets](#)

[DAS 107-004-120 Cyber and Information Security Incident Response](#)

[ODHSOHA 090-005 Information Security Incident Management Policy](#)

[ODHSOHA 070-014 Information Technology Asset Management Policy](#)

[OHA 100-014 Report and Response to Privacy Incidents](#)

This policy shall be reviewed at least once every year to ensure relevance.

Contact

Information Security and Privacy Office (ISPO)

ispo.inforisk@odhs.oregon.gov

Policy history

Version 1 DHSOHA 090-006 established 03/11/2015

Version 2 DHSOHA 090-006 reviewed annually 03/04/2016

Version 3 DHSOHA 090-006 revised 11/7/2016

Version 3 ODHSOHA 090-006 reviewed 11/02/2020

Version 3 ODHSOHA 090-006 reviewed 10/04/2021

Version 4 ODHSOHA 090-006 revised 12/12/2022

Version 5 ODHSOHA 090-006 revised 11/06/2023

Version 6 ODHSOHA 090-006 revised 11/01/2024

Version 7 ODHSOHA 090-006 revised 07/01/2026

Keywords

ISRA, protect, safeguard, threats, vulnerability

You can get this document in other languages, large print, braille or a format you prefer free of charge. Contact Publications and Creative Services at dhs-oha.publicationrequest@odhsoha.oregon.gov or 503-373-1342. We accept all relay calls.